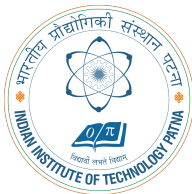


Chapter 5: Networks

Dr. Mayank Agarwal

Department of CSE
IIT Patna

CS457 Big Data Security
Jan-April 2026



Security in Computing, Fifth Edition I

Chapter 5: Networks

- **Protecting Communications and Infrastructure:** Securing data in transit (confidentiality, integrity) and the underlying hardware (routers, switches).
- **Network Security Architecture and Protocols:** Designing secure topologies and leveraging protocols like IPSec, TLS, and DNSSEC.
- **Defending Against Network-based Attacks:** Implementing controls like firewalls, IDS/IPS, and Zero Trust to mitigate threats such as DDoS, MitM, and reconnaissance.

Network security is the practice of protecting the usability and integrity of network infrastructure and data. In India's rapidly digitizing landscape - from UPI payments to Aadhaar-linked services - the network is both the primary attack vector for adversaries and the critical perimeter that must be defended.

Chapter 5 Learning Objectives I

- **Understand Network Security Fundamentals:** Core principles (CIA triad), models (**Zero Trust, Defense in Depth**), and the OSI/TCP/IP model vulnerabilities.
- **Learn About Network Attack Vectors:** Reconnaissance, access attacks, Denial of Service (DoS), and malware propagation techniques.
- **Study Defense Mechanisms:** Deep dive into firewalls (NGFW, WAF), IDS/IPS (signature vs. anomaly), VPNs (IPSec, SSL), and network segmentation.
- **Analyze Wireless & Mobile Security:** Wi-Fi security (WPA3), cellular network risks (SS7, 5G), and the unique threats to mobile devices.

Chapter 5 Learning Objectives II

- **Examine Cloud & IoT Security:** Shared responsibility models in AWS/Azure, securing IoT fleets (like smart meters in India), and industrial control systems (SCADA).
- **Understand Monitoring & Response:** Network traffic analysis, forensic investigation, and incident response planning.

These objectives aim to bridge the gap between securing individual systems and protecting an entire organization's networked resources.

The Network Security Challenge I

- **Inherently Insecure Medium:** Data traverses networks owned by third parties (ISPs, public Wi-Fi). Think of sending a physical letter through a series of unsecured post offices.
- **Expanded Attack Surface:** The proliferation of IoT devices, remote work, and cloud adoption has dissolved the traditional network perimeter. Every connected device - from a smart bulb in a Mumbai office to a sensor in a Bengaluru data center - is a potential entry point.
- **Complexity:** Modern networks are a complex web of routers, switches, firewalls, load balancers, and SD-WAN appliances. A misconfiguration in a single device can cascade into a major vulnerability.

The Network Security Challenge II

- **Visibility Challenges:** With encrypted traffic (HTTPS, DoH) becoming the norm, traditional deep packet inspection (DPI) is blind. Security teams must analyze metadata and flow data to detect anomalies.
- **Evolving Threats:** Attackers continuously innovate. Ransomware groups now employ "double extortion" (exfiltration + encryption), and DDoS attacks are leveraging IoT botnets (like Mirai) to generate terabits per second of traffic.
- **Performance vs. Security Trade-offs:** Enforcing strong security controls (e.g., full TLS inspection, complex firewall rules) introduces latency. Finding the balance that maintains user experience (especially critical for India's high-volume digital payment gateways like Paytm or PhonePe) is a constant struggle.

Network Security Models I

- **Perimeter Security (Castle-and-Moat):** Focuses on building a strong outer wall (firewall) to keep attackers out. Assumes that everything inside the wall is trustworthy. *Failure:* Once the wall is breached, the attacker has free rein (e.g., Target 2013 breach).
- **Zero Trust (ZTNA):** The guiding principle: "Never trust, always verify." No user or device is trusted by default, even if inside the corporate network. Access is granted based on identity, device health, and context. A cornerstone of the Indian government's *National Cyber Security Strategy*.
- **Defense in Depth:** Layered security. An attacker must defeat multiple controls: a firewall, then an IPS, then host-based Endpoint Detection and Response(EDR), and finally data encryption. If one layer fails, others remain.

Network Security Models II

- **Deperimeterization:** The concept that data and users are no longer confined to a physical office. Security controls must follow the data to the cloud and the user to their home or coffee shop.
- **Software-Defined Perimeter (SDP):** A Zero Trust implementation that creates a one-to-one network connection between a user and the resource they need. The resource is hidden from the internet (dark cloud), drastically reducing the attack surface.
- **Secure Access Service Edge (SASE):** SASE (Secure Access Service Edge) converges SD-WAN (Software-Defined Wide Area Network), SWG (Secure Web Gateway), CASB (Cloud Access Security Broker), and ZTNA (Zero Trust Network Access) into a single cloud-delivered service. Ideal for organizations with a distributed workforce.

OSI and TCP/IP Security Considerations I

- **Physical Layer (Layer 1):** Vulnerable to cable tapping, signal interception (e.g., Van Eck phreaking), and physical damage.
- **Data Link Layer (Layer 2):** Attacks operate within a local network.
 - **MAC Spoofing:** Impersonating an authorized device.
 - **ARP Poisoning:** Associating the attacker's MAC address with the IP of a legitimate host (e.g., the default gateway) to perform Man-in-the-Middle (MitM) attacks.
 - **VLAN Hopping:** Bypassing VLAN segmentation to access restricted network segments.
- **Network Layer (Layer 3):**
 - **IP Spoofing:** Creating IP packets with a forged source address to bypass ACLs or launch DDoS attacks.
 - **Routing Attacks:** Injecting false routing table entries (BGP hijacking) to redirect traffic. *Indian Context:* In 2019, a BGP leak by a Chinese telecom briefly rerouted traffic for major US and European services, underscoring global routing fragility.

- **Transport Layer (Layer 4):**

- **TCP SYN Flood:** Exhausting server resources by sending incomplete connection requests.
- **Session Hijacking:** Taking over a valid TCP session after authentication has occurred.

- **Application Layer (Layer 5-7):**

- Protocol-specific attacks like SQL injection, cross-site scripting (XSS), and DNS tunneling.

Network Protocol Security Analysis I

- **TCP/IP Design Flaws:** The suite was developed in the 1970s for a trusted, academic research environment. Security was not a primary design requirement, leading to foundational flaws.
- **Lack of Authentication:** TCP/IP has no built-in mechanism to verify that a packet genuinely originates from its claimed source IP address. This makes IP spoofing trivial.
- **Clear Text Protocols:** Legacy protocols like FTP, Telnet, HTTP, and SNMPv1/v2 transmit credentials and data in plaintext. An attacker on the same network segment can easily capture this sensitive information. *Indian Example:* Many older industrial control systems in Indian power grids still rely on these unsecured protocols.
- **Security Add-ons:** Security protocols were bolted on later.
 - **IPSec:** Added to secure IP communications, but is complex to configure.

- **SSL/TLS:** Added to secure web traffic, but its many versions and configurations create vulnerabilities (e.g., POODLE, Heartbleed).
- **Protocol Vulnerabilities:** Implementation flaws in protocol stacks can lead to remote code execution (e.g., the 2020 "Bad Neighbor" bug in Windows TCP/IP stack).

Common Network Attacks: Reconnaissance I

- **Port Scanning:** Tools like `nmap` and `masscan` probe target IP ranges to discover open ports and running services. `masscan` is famous for scanning the entire internet in minutes.
- **OS Fingerprinting:** Analyzing responses to crafted packets (e.g., variations in TCP window size, TTL) to guess the target's operating system (e.g., Windows vs. Linux). This helps attackers tailor their exploits.
- **Banner Grabbing:** Connecting to an open service (like a web server on port 80) and reading the service banner: `Apache/2.4.41 (Ubuntu)`. This reveals specific versions vulnerable to known CVEs.
- **Network Mapping:** Using `traceroute` or `pathping` to discover routers, firewalls, and the logical topology of the target network.

Common Network Attacks: Reconnaissance II

- **DNS Enumeration:** Performing zone transfers (if allowed) or DNS brute-forcing to discover subdomains (e.g., `admin.example.com`, `vpn.example.com`). This reveals internal infrastructure.
- **SNMP Sweeping:** Querying network devices using the **Simple Network Management Protocol (SNMP)**. Misconfigured SNMP (with default community strings like "public") can leak detailed information about devices, users, and even configuration.
- **Defense:** Network segmentation, stateful firewalls that block unauthorized scanning, and port knocking/hiding techniques.

● Password Attacks:

- **Brute Force:** Trying every possible character combination.
- **Dictionary:** Using a pre-defined list of common passwords (like 'password123', 'admin@123').
- **Credential Stuffing:** Using username/password pairs leaked from one breach to attempt login on other services.
- *Indian Context:* In 2023, CERT-In reported a significant rise in credential stuffing attacks targeting Indian banking and e-commerce portals.
- **Exploitation:** Leveraging a software vulnerability (e.g., a buffer overflow in a web server) to execute arbitrary code or bypass authentication. Exploit frameworks like Metasploit automate this process.

Common Network Attacks: Access Attacks II

- **Man-in-the-Middle (MitM):** The attacker intercepts communication between two parties. Common on unencrypted public Wi-Fi.
- **Session Hijacking:** Stealing a valid session token (e.g., a cookie after a user logs in) to assume that user's identity without needing their password.
- **ARP Poisoning:** A Layer 2 MitM technique. The attacker sends forged ARP replies, linking their MAC address to the IP of the router. All traffic destined for the router is then sent to the attacker.
- **DHCP Spoofing:** An attacker sets up a rogue DHCP server on a network. When clients request an IP, they receive the rogue server's configuration, which can route all their traffic through the attacker.

Common Network Attacks: Denial of Service I

- **Volumetric Attacks:** Overwhelm the target's network bandwidth. Common vectors: UDP floods (spoofed UDP packets), ICMP floods (pings), and amplified DNS/NTP attacks. *Example:* A DNS amplification attack uses 3rd-party DNS servers to send a large response (up to 100x larger than the query) to a spoofed victim IP.
- **Protocol Attacks:** Exploit weaknesses in protocols like TCP.
 - **SYN Flood:** The attacker sends a flood of SYN packets but never completes the three-way handshake, exhausting the target's connection table (backlog).
 - **Ping of Death:** Sending an oversized ICMP packet that causes a buffer overflow.
- **Application Layer Attacks:** Target specific web applications. A low-and-slow HTTP flood sends seemingly legitimate requests that keep server connections open, consuming resources without generating high bandwidth.

Common Network Attacks: Denial of Service II

- **Distributed DoS (DDoS):** A large-scale attack from multiple, often compromised, sources (a botnet). These are extremely difficult to block because traffic appears to come from millions of distinct IPs.
- **Amplification Attacks:** Leverage protocols where a small request generates a much larger response (DNS, NTP, Memcached). The attacker spoofs the victim's IP, causing the reflector to flood the victim.
- **Permanent DoS (PDoS):** Physically damaging a device. In 2019, a hacker caused a bricking (bricking) of Amazon Kindle devices by exploiting a vulnerability, rendering them permanently unusable.

Common Network Attacks: Malware Distribution I

- **Drive-by Downloads:** An attacker compromises a legitimate website (often using a vulnerable plugin) to inject malicious code. Visiting the site automatically downloads and installs malware without any user interaction.
- **Email Attachments:** Phishing emails with malicious attachments. Modern malware often hides in macro-enabled Office documents (.docm, .xlsm). *Indian Context:* Tax-themed phishing emails surge during the Indian tax filing season, attempting to steal credentials or deploy malware.
- **Watering Hole Attacks:** An attacker profiles a specific group (e.g., Indian government employees) and compromises a website they are known to frequent. They then wait for the target group to visit the infected site.

Common Network Attacks: Malware Distribution II

- **Malvertising:** Injecting malicious code into legitimate online advertising networks. Ads can redirect users to exploit kits or deliver malware without requiring the user to click.
- **Worm Propagation:** Self-replicating malware that spreads across a network by exploiting vulnerabilities (e.g., EternalBlue used by WannaCry) without user interaction.
- **Botnet Recruitment:** Infected devices are recruited into a botnet. They then wait for commands from a Command-and-Control (C2) server to perform DDoS attacks, send spam, or mine cryptocurrency.

Firewalls: Fundamental Concepts I

- **Definition:** A network security device that monitors and filters incoming and outgoing network traffic based on a defined set of security rules. It acts as a chokepoint, enforcing the security policy.
- **Default Policies:**
 - **Default Deny (Whitelist):** "Everything that is not explicitly permitted is denied." This is the recommended best practice for security.
 - **Default Allow (Blacklist):** "Everything that is not explicitly denied is allowed." This is more permissive and creates a larger attack surface.
- **Rule Evaluation Order:** Rules are processed in order. The first rule that matches a packet determines its fate. A common best practice is to place specific, high-priority rules (e.g., allow traffic for a critical server) before generic rules (e.g., deny all).
- **Stateful vs. Stateless:**

Firewalls: Fundamental Concepts II

- **Stateless:** Filters each packet in isolation based on header information (source/dest IP, port). It doesn't know if a packet is part of an established connection.
- **Stateful:** Maintains a state table that tracks active connections (e.g., TCP handshake completed). It can intelligently allow return traffic for outbound connections while blocking unsolicited inbound traffic.
- **Deployment Locations:**
 - **Perimeter:** Between the internal network and the internet.
 - **Internal Segmentation:** Placed between different internal zones (e.g., finance dept. vs. engineering dept.).
 - **Host-based:** Software firewall (like Windows Defender Firewall) on an individual endpoint.

Firewall Types and Architectures I

- **Packet Filtering Firewall:** The most basic type. Operates at Layers 3 and 4. It inspects header information (IP, port, protocol) against ACLs. It is stateless, fast, but vulnerable to IP spoofing.
- **Stateful Inspection Firewall:** Overcomes the stateless limitation. It maintains a state table, tracking connections. It blocks unsolicited inbound packets that aren't associated with an outbound connection. It's more intelligent than packet filtering.
- **Application/Proxy Firewall:** Acts as an intermediary. It terminates the client connection and creates a separate connection to the destination. It understands application-layer protocols (HTTP, FTP, SMTP) and can inspect payload content, not just headers.
- **Next-Generation Firewalls (NGFW):** The industry standard (e.g., Palo Alto Networks, Fortinet, Check Point). NGFWs integrate:

Firewall Types and Architectures II

- **Stateful inspection + Application awareness** (identifies applications regardless of port).
- Intrusion Prevention System (IPS) capabilities.
- SSL/TLS inspection.
- Threat intelligence integration.
- **Web Application Firewalls (WAF)**: Specialized for protecting web applications. It inspects HTTP traffic for attacks like **SQL injection** (e.g., `SELECT * FROM users WHERE username = 'admin' --`) and XSS. *Indian Context*: Critical Indian financial and government portals (e.g., IRCTC, GST portal) are protected by WAFs.
- **Unified Threat Management (UTM)**: An all-in-one appliance combining firewall, IPS, antivirus, anti-spam, VPN, and **content filtering**. Popular in small-to-medium businesses (SMBs).

Firewall Rule Design Best Practices I

- **Least Privilege:** Grant only the minimum necessary access. If a server needs to be accessed only from the HR department's subnet, the rule should explicitly allow HR and deny all others. Avoid using 'any' in source/destination/port fields.
- **Explicit Deny:** Always end the rulebase with a catch-all "deny all" rule. This ensures any traffic not explicitly permitted is dropped. Log this rule to identify unexpected traffic.
- **Documentation:** Every rule must have a comment. `allow tcp 10.1.1.0/24 10.2.2.5 443` is unhelpful. `allow tcp 10.1.1.0/24 10.2.2.5 443 # Allow HR subnet to access finance web server for payroll app` is maintainable.

Firewall Rule Design Best Practices II

- **Regular Review:** Rule sets accumulate "rule sprawl" over time. Old, unused rules (e.g., for decommissioned servers) create clutter and potential security gaps. Review rulebase at least quarterly.
- **Change Management:** All rule modifications should require a formal ticket, with approval from a security lead. This prevents unauthorized changes and ensures accountability.
- **Testing:** Use tools to simulate traffic and verify that rules behave as intended. Many firewalls offer "policy verification" or "rule hit count" features to validate rule usage.
- **Logging:** Enable logging on "deny" rules to detect potential reconnaissance or attacks. Logging on "allow" rules should be selective to avoid overwhelming storage (e.g., log for critical servers only).

Intrusion Detection Systems (IDS) I

- **Purpose:** A detective control that monitors network traffic or system activities for suspicious behavior and generates alerts. It does not take action to block traffic.
- **Detection Methods:**
 - **Signature-based:** Compares traffic patterns against a database of known attack signatures (e.g., a specific byte sequence in a packet). *Pros:* Highly accurate for known attacks. *Cons:* Cannot detect new (zero-day) attacks; requires constant signature updates.
 - **Anomaly-based:** Establishes a baseline of "normal" network behavior (e.g., average bandwidth, protocol usage, connection patterns). It then alerts on deviations from this baseline. *Pros:* Can detect novel attacks and zero-days. *Cons:* Prone to high false positives (e.g., a legitimate large file transfer might be flagged as anomalous).
 - **Heuristic/Behavioral:** Uses rule-based analysis to detect attacks. For example, a rule might flag "more than 10 failed login attempts in 60 seconds."

- **Deployment Types:**

- **Network-based IDS (NIDS):** Deployed at strategic points (e.g., behind the firewall) to monitor network traffic. It uses promiscuous mode to capture all traffic on a network segment.
- **Host-based IDS (HIDS):** Installed on individual systems (servers, workstations). It monitors system logs, file system changes, and process activity.

- **Response:** IDS is passive. It logs alerts and notifies administrators (via email, SIEM console). IPS, by contrast, is active.

Intrusion Prevention Systems (IPS) I

- **Definition:** An IPS builds on IDS capabilities by adding the ability to actively block or prevent detected threats. It's essentially an IDS placed inline with network traffic.
- **Deployment Modes:**
 - **Inline (Blocking):** The IPS sits directly in the traffic path. All traffic passes through it. If a threat is detected, the IPS can drop the packet, reset the connection, or block the source IP.
 - **Passive (Monitoring):** The IPS operates like an IDS, monitoring a mirrored port without blocking traffic. This is often used for initial testing and tuning.
- **Detection Engines:** Similar to IDS (signature, anomaly, heuristic), but with automated response capabilities.
- **Challenges:**

Intrusion Prevention Systems (IPS) II

- **False Positives:** If an IPS incorrectly identifies legitimate traffic as malicious (false positive), it can block business-critical applications, causing a denial of service. Careful tuning is crucial.
- **Throughput:** Inline inspection adds latency. The IPS must be sized appropriately to handle peak traffic loads.
- **Response Actions:**
 - **Block:** Drop the packet and all future packets from the source.
 - **Reset Connection:** Send TCP RST packets to terminate the session.
 - **Rate Limit:** Throttle traffic from a suspicious source to mitigate DDoS while allowing some legitimate traffic.
 - **Alert:** Log and alert only (passive mode).
- **Next-Generation IPS (NGIPS):** Integrated with threat intelligence, application control, and user identity (via Active Directory integration) for contextual, granular blocking.

IDS/IPS Evasion Techniques I

- **Fragmentation:** Splitting an attack payload across multiple small IP fragments. If the IDS/IPS does not properly reassemble fragments, the malicious pattern might be missed.
- **Encryption:** Attackers use HTTPS, SSH, or custom encryption to hide malicious payloads. An IPS cannot inspect what it cannot decrypt. Enterprise solutions use TLS inspection (man-in-the-middle) to decrypt, inspect, and re-encrypt traffic.
- **Protocol Manipulation:** Using non-standard ports (e.g., SSH on port 443, HTTP on port 53) to bypass firewall rules that only inspect well-known ports.
- **Traffic Normalization:** Different encodings of the same attack. For example, a URL-encoded SQL injection: `%27 OR 1=1 --` vs. raw `' OR 1=1 --`. If the IDS normalizes differently than the target server, the attack can slip through.

- **Timing Attacks:** "Low and slow" attacks that spread malicious activity over a long period to avoid crossing detection thresholds.
- **Polymorphic Code:** Malware that mutates its code signature (while preserving functionality) for each infection. Signature-based IDS cannot keep up.
- **Noise Generation:** Attackers intentionally generate high-volume, easily detectable "noise" (e.g., port scans) to distract SOC analysts while launching a more sophisticated, stealthy attack.

Virtual Private Networks (VPN) I

- **Purpose:** To create a secure, encrypted tunnel over an untrusted network (like the internet), providing confidentiality, integrity, and (often) authentication.
- **VPN Types:**
 - **Site-to-Site (Gateway-to-Gateway):** Connects entire networks together. Example: Connecting a branch office in Chennai to the headquarters in Mumbai across the internet. The VPN is established between the edge firewalls or routers.
 - **Remote Access (Client-to-Site):** Connects an individual user (e.g., an employee working from home) to the corporate network. The user installs a VPN client on their laptop.
- **Protocols:**
 - **IPSec:** A suite of protocols. Operates at Layer 3. Used heavily in site-to-site VPNs. Can operate in Tunnel Mode (encrypts entire IP packet) or Transport Mode (encrypts payload only).

Virtual Private Networks (VPN) II

- **SSL/TLS (OpenVPN):** Operates at Layer 4-7. Most common for remote access VPNs because it uses port 443 (HTTPS), which is almost always open on firewalls.
- **WireGuard:** A modern, high-performance VPN protocol. It's much simpler and faster than IPsec and OpenVPN, with a smaller codebase (less attack surface).
- **Authentication:** Pre-shared keys (PSK), digital certificates (X.509), or integration with Multi-Factor Authentication (MFA) like OTP or biometrics.
- **Encryption:** AES-256-GCM (IPsec, OpenVPN) or ChaCha20-Poly1305 (WireGuard).

VPN Security Considerations I

- **Split Tunneling:** A configuration that allows remote users to access the corporate network (via VPN) and the internet (via their local ISP) simultaneously.
 - *Risk:* If the user's local network is compromised, an attacker could pivot from the user's device into the corporate network through the VPN tunnel.
 - *Alternative:* Force Tunneling (Full Tunnel) sends all traffic through the corporate network, but this increases bandwidth costs and latency.
- **DNS Leakage:** A vulnerability where DNS queries are sent to the user's ISP's DNS server instead of through the VPN tunnel. This can reveal the websites the user is visiting, defeating the purpose of the VPN.
- **Kill Switch:** A client feature that automatically cuts off all internet traffic if the VPN connection drops unexpectedly, preventing unencrypted data from being sent over the untrusted network.

VPN Security Considerations II

- **Perfect Forward Secrecy (PFS):** A property where the session keys used for encryption cannot be derived from a long-term secret key. If a server's private key is compromised in the future, past sessions remain secure.
- **VPN Concentrator Security:** The VPN gateway (the endpoint of the tunnel) is a critical asset. It must be hardened, patched regularly, and placed in a DMZ with strict firewall rules.
- **Logging Policies:** VPN providers (especially commercial ones) may log user activity. Privacy-conscious organizations must review logging policies to understand what is collected.
- **Client Security:** The remote endpoint (user's device) must be secure. If the endpoint is infected with malware, the VPN tunnel becomes a secure conduit for malware to enter the corporate network.

- **WEP (Wired Equivalent Privacy):** The first Wi-Fi security protocol. Severely broken. The RC4 encryption key can be cracked in minutes using tools like aircrack-ng. Never use WEP.
- **WPA (Wi-Fi Protected Access):** An interim standard that replaced WEP. Used TKIP (Temporal Key Integrity Protocol), which was a step up but still had fundamental weaknesses. Deprecated.
- **WPA2:** The long-standing standard. Uses AES-CCMP for strong encryption. However, it is vulnerable to the KRACK (Key Reinstallation Attack) attack, which can force a client to reuse a nonce, breaking encryption. While patched, many IoT devices remain vulnerable.
- **WPA3:** The current standard. Provides significant improvements:

Wireless Network Security II

- SAE (Simultaneous Authentication of Equals): Replaces Pre-Shared Key (PSK) with a more secure handshake, making it resistant to offline dictionary attacks (the weakness of WPA2-PSK).
- Enhanced Open (OWE): Provides encryption even on open networks (like public Wi-Fi) without requiring a password.
- 192-bit security suite: Aligns with commercial and government security standards.
- **Enterprise Security (802.1X/EAP):** For corporate environments. Uses a RADIUS server to authenticate users individually (not just the device). Each user gets unique credentials, enabling granular access control and accounting.
- **Hidden SSIDs:** A common "security through obscurity" technique. Hiding the SSID does not make the network secure. The SSID is still broadcast in probe requests, and attackers can easily discover it.

Wireless Attack Vectors I

- **Evil Twin/Rogue Access Points:** The attacker sets up a fake AP with the same SSID as a legitimate network (e.g., "CoffeeShopWiFi"). When users connect, the attacker can perform MitM attacks, capture credentials, and inject malware.
- **Deauthentication Attacks:** The attacker sends deauthentication frames (which are unauthenticated in 802.11) to disconnect a client from a legitimate AP. The client then automatically reconnects, providing an opportunity for the attacker to capture the 4-way handshake for offline brute-forcing (WPA2) or to force the client to connect to an evil twin.
- **Packet Injection:** Injecting crafted packets into wireless traffic. Used in deauthentication attacks and to deliver exploit payloads.

Wireless Attack Vectors II

- **WPS Attacks:** Wi-Fi Protected Setup (WPS) was designed for easy device onboarding. The PIN-based method (8 digits) is weak. An attacker can brute-force the PIN in a few hours, revealing the WPA2 password.
- **KRACK Attack:** Key Reinstallation Attack. Exploits a flaw in the WPA2 4-way handshake, tricking a client into reinstalling an already-in-use encryption key, allowing the attacker to decrypt traffic.
- **Dragonblood Attack:** A set of vulnerabilities discovered in the early implementation of WPA3. They allowed downgrade attacks to WPA2 and side-channel leaks. These have been patched.
- **War Driving:** The act of driving around with a laptop, GPS, and a Wi-Fi adapter to map wireless networks. Attackers identify vulnerable networks for later targeting.

Domain Name System (DNS) Security I

- **DNS Cache Poisoning:** An attacker injects a false DNS record into a recursive resolver's cache. For example, they poison the record for `example.com` to point to the attacker's IP address. All users of that resolver will be redirected to the malicious site.
- **DNS Hijacking:** More aggressive than poisoning. Attackers compromise a domain's registration at the registrar level, changing the authoritative nameservers to ones they control. *Indian Example:* In 2019, the DNS of a major Indian bank was hijacked, redirecting customers to a phishing site.
- **DNS Tunneling:** A covert channel technique. Attackers use DNS queries and responses to encapsulate non-DNS traffic (like C2 commands or data exfiltration). Since DNS is rarely inspected, this allows malware to bypass firewalls.

Domain Name System (DNS) Security II

- **DNSSEC (Domain Name System Security Extensions):** Adds a layer of cryptographic authentication to DNS responses. It uses digital signatures to ensure that the DNS data received is identical to the data published by the domain owner, preventing cache poisoning. However, it does not provide confidentiality (encryption).
- **DNS over HTTPS/TLS (DoH/DoT):** Encrypts DNS queries, preventing eavesdropping and manipulation. DoH uses port 443 (HTTPS), making it look like web traffic and hard to block. DoT uses a dedicated port (853). This improves user privacy but can challenge enterprise security teams who rely on DNS filtering for threat detection.

- **Response Policy Zones (RPZ):** A DNS firewall technique. The DNS server uses a policy zone to override responses for known malicious domains. If a client queries `bad-site.com`, the DNS server returns a safe sinkhole IP address instead of the actual IP, blocking access.

- **SPF (Sender Policy Framework):** A DNS record that lists which mail servers are authorized to send email for a domain. A receiving server can check if the sending server's IP is on the SPF list.
- **DKIM (DomainKeys Identified Mail):** Uses cryptographic signatures. The sending server adds a digital signature to the email header. The receiving server looks up the public key in DNS and verifies the signature, ensuring the email was not tampered with during transit.
- **DMARC (Domain-based Message Authentication, Reporting & Conformance):** Builds on SPF and DKIM. It provides two key functions:
 - **Policy:** Tells the receiving server what to do if an email fails SPF or DKIM checks (e.g., `p=reject`, `p=quarantine`, `p=none`).

- **Reporting:** Allows domain owners to receive reports about which servers are sending email on their behalf and which emails are failing authentication.
- **MTA-STS (Mail Transfer Agent Strict Transport Security):** A policy that tells sending mail servers that they must use TLS (encrypted connection) when delivering mail to the receiving domain, preventing downgrade and MitM attacks.
- **DANE (DNS-based Authentication of Named Entities):** Uses DNSSEC to publish the TLS certificate of the receiving mail server in DNS. This allows senders to verify the certificate, reducing reliance on public Certificate Authorities (CAs).

- **PGP/S/MIME:** Protocols for end-to-end email encryption. PGP (Pretty Good Privacy) uses a web-of-trust model, while S/MIME uses a hierarchical CA model. Adoption is low due to key management complexity.

- **SSL/TLS Evolution:**

- **SSL 2.0/3.0:** Deprecated. Vulnerable to POODLE and other attacks.
- **TLS 1.0/1.1:** Also deprecated by industry standards (PCI DSS, IETF). Vulnerable to BEAST and other downgrade attacks.
- **TLS 1.2:** The most widely deployed version. Supports modern cipher suites (e.g., ECDHE-ECDSA-AES256-GCM-SHA384).
- **TLS 1.3:** The current standard. Major improvements: simplified handshake (1-RTT vs. 2-RTT), mandatory Perfect Forward Secrecy (PFS), and removal of weak ciphers (e.g., RSA key exchange, CBC mode).

- **Certificate Authorities (CAs):** The trust anchors of the web. Browsers trust a list of root CAs. CAs issue certificates to domains. A compromised CA (like DigiNotar in 2011) can issue rogue certificates for any domain, enabling MitM attacks.

- **Certificate Transparency (CT):** An open framework that requires CAs to publicly log every certificate they issue. Domain owners can monitor these logs to detect rogue certificates issued for their domain.
- **HTTPS Everywhere:** The movement to encrypt all web traffic by default. Major browsers now mark HTTP sites as "Not Secure."
- **SSL/TLS Inspection:** In an enterprise, a device (like a proxy or NGFW) intercepts TLS connections, decrypts them, inspects the content for malware, and then re-encrypts the traffic to the destination. This is essential for security but raises privacy concerns and requires careful handling of certificates.

Network Segmentation Strategies I

- **Purpose:** Segmentation is a key control for limiting lateral movement. It ensures that a compromise in one segment (e.g., guest Wi-Fi) cannot easily spread to another (e.g., payment card network).
- **Physical Segmentation:** The most secure but least flexible. Uses completely separate physical cables, switches, and routers for different networks (e.g., a classified network physically isolated from the corporate network).
- **VLANs (Virtual LANs):** Layer 2 segmentation. Switches partition broadcast domains. Traffic between VLANs must pass through a Layer 3 device (router/firewall), where security policies can be enforced. *Risk:* VLAN hopping.

Network Segmentation Strategies II

- **VRFs (Virtual Routing and Forwarding):** Layer 3 segmentation. A single router can maintain multiple independent routing tables (VRFs). This provides segmentation at the IP layer without needing multiple physical routers. Common in data centers and service providers.
- **Microsegmentation:** A software-defined approach, typically in cloud or virtualized environments. It enforces per-workload or per-application policies. For example, a policy that allows only web-server-01 to talk to db-server-01 on port 3306.
- **Zero Trust Segmentation:** Identity-based policies. Instead of relying on IP addresses, access is granted based on user identity, device, and application. This is the ultimate goal for modern network security.

Network Access Control (NAC) I

- **Definition:** A security solution that enforces policy on devices attempting to access the network, ensuring they are authorized and compliant.
- **802.1X:** The IEEE standard for port-based network access control. It authenticates devices (wired or wireless) before they are allowed to communicate on the network. The authentication is handled by a RADIUS server.
- **Posture Assessment:** Before granting network access, a NAC system checks the device's security state:
 - Is antivirus software installed and updated?
 - Is the operating system patched?
 - Is the firewall enabled?
 - Is the device a corporate-managed asset?

Network Access Control (NAC) II

- **Guest Access:** NAC provides isolated, internet-only access for visitors. Guest accounts have time-bound access and are often provisioned via a self-service portal (e.g., "register with your phone number").
- **BYOD Support:** NAC manages personal devices (Bring Your Own Device) by segregating them from corporate assets, often placing them on a dedicated VLAN with limited access.
- **Remediation:** If a device is non-compliant (e.g., missing a critical patch), NAC can redirect it to a quarantine network. This network provides access only to update servers, allowing the user to remediate the issue before gaining full access. *Indian Context:* NAC is widely adopted in Indian BFSI (Banking, Financial Services, and Insurance) sector to meet RBI (Reserve Bank of India) cybersecurity guidelines.

- **Virtual Networks (VPC):** In AWS, Azure, and GCP, you create isolated virtual networks (Virtual Private Clouds). These are software-defined and act like your own private data center in the cloud.
- **Security Groups:** A stateful, virtual firewall at the instance (VM) level. It functions as a whitelist: you specify allowed inbound and outbound traffic. Security groups are the primary control for securing individual cloud resources.
- **Network ACLs (NACLs):** A stateless firewall at the subnet level. They provide a second layer of defense, acting as a coarse-grained filter for all resources in a subnet.

Cloud Network Security II

- **Cloud Firewalls (WAF/IPS):** Cloud providers offer managed security services. AWS WAF, Azure WAF, and Cloud Armor protect web applications from OWASP Top 10 threats.
- **Private Links/Endpoints:** These allow you to access cloud services (like AWS S3 or Azure SQL) over a private IP address within your VPC, rather than going over the public internet. This reduces exposure.
- **Transit Gateways:** A central hub for routing traffic between multiple VPCs, on-premises networks, and VPN connections. They simplify complex cloud networking topologies.
- **Shared Responsibility Model:** In the cloud, the provider is responsible for the *security of the cloud* (physical data centers, hypervisor), while the customer is responsible for *security in the cloud* (network configuration, access controls, data encryption).

Network Monitoring and Traffic Analysis I

- **NetFlow/sFlow/IPFIX:** These are protocols for collecting "flow" metadata. Instead of capturing every packet, they summarize network connections: source/dest IP, ports, protocol, bytes transferred, and timestamps. This is efficient for long-term storage and identifying broad patterns.
- **Packet Capture (PCAP):** Full packet inspection, capturing every byte. Tools like tcpdump (CLI) and Wireshark (GUI) are used for deep analysis, troubleshooting, and forensic investigations. PCAP is storage-intensive.
- **SIEM Integration:** Network monitoring tools feed flow data, logs, and alerts into a Security Information and Event Management (SIEM) system (e.g., Splunk, QRadar). The SIEM correlates this network data with firewall logs, endpoint logs, and identity logs to provide a unified view.

Network Monitoring and Traffic Analysis II

- **Behavioral Analysis:** A baseline of "normal" network behavior is established. Machine learning algorithms then detect anomalies: a new connection to a foreign country, a sudden spike in outbound traffic, or unusual protocols.
- **Threat Intelligence Feeds:** Feeds that provide lists of known malicious IP addresses, domains, and file hashes. Monitoring tools can alert when internal systems connect to these known indicators of compromise (IoCs).
- **Encrypted Traffic Analysis (ETA):** With the rise of TLS 1.3, payload inspection is no longer possible. ETA uses metadata (e.g., packet lengths, timing, byte distributions) to identify malicious encrypted traffic patterns, such as ransomware beaconing.

- **Evidence Collection:** Network forensics involves preserving and analyzing:
 - Packet captures (PCAPs) from the time of the incident.
 - NetFlow/IPFIX records for historical connection data.
 - Firewall, IDS/IPS, and VPN logs.
 - Router and switch logs (e.g., for configuration changes).
- **Chain of Custody:** It is critical to document the evidence collection process: who collected the evidence, when, and how. This preserves the admissibility of evidence in legal proceedings.
- **Timeline Reconstruction:** The investigator correlates data from multiple sources to build a chronological timeline of the attack. This reveals the order of events: initial recon, exploitation, lateral movement, and data exfiltration.

Network Forensic Investigation II

- **Malware Traffic Analysis:** Analyzing network traffic to understand malware behavior. For example, identifying the C2 server IP, the protocol used, and the data being exfiltrated.
- **Attribution Challenges:** Attribution is notoriously difficult. Attackers can use:
 - **IP Spoofing:** Forging source IP addresses.
 - **Proxy Chains:** Routing through multiple compromised hosts.
 - **Tor Network:** Anonymizing traffic through onion routing.
 - **Compromised VPNs:** Hiding behind legitimate VPN services.
- **Tools:** NetworkMiner (extracts files from PCAPs), Xplico (web forensics), Security Onion (Linux distro for NSM), and Wireshark.

- **5G/6G Networks:**
 - **Network Slicing:** Creates virtual, isolated network slices for different use cases (e.g., a slice for autonomous vehicles, a slice for IoT sensors). Security must ensure isolation between slices to prevent cross-slice attacks.
 - **Edge Computing:** Processing moves to the edge of the network, closer to the user. This expands the attack surface; security must extend to distributed edge nodes.
- **Satellite Internet (e.g., Starlink):** Provides global connectivity. Security challenges include:
 - **Physical Security:** User terminals (dishes) are deployed in uncontrolled environments, could be stolen or tampered with.
 - **Jamming and Eavesdropping:** The wireless link between the terminal and the satellite can be intercepted.

Emerging Network Technologies Security II

- **Li-Fi (Light Fidelity):** Uses visible light communication (VLC). It is inherently more secure because light does not pass through walls, providing physical containment. However, it still requires encryption.
- **Blockchain Networks:** Decentralized networks. Security is based on consensus mechanisms (e.g., Proof of Work). Vulnerabilities include 51% attacks, smart contract bugs, and wallet theft.
- **Mesh Networks:** Decentralized, self-healing networks (e.g., Zigbee, Thread). Security is challenging due to the lack of a central gateway to enforce policy. Each node must be trusted or secured with strong encryption.

Case Study: Target Data Breach (2013) I

- **Attack Vector:** Credentials for an HVAC (Heating, Ventilation, and Air Conditioning) vendor, Fazio Mechanical, were stolen via a phishing email.
- **Network Segmentation Failure:** The vendor network was not properly segmented from the main corporate network and, critically, from the payment card (POS) network. The vendor's access should have been limited to HVAC management, not to other systems.
- **Lateral Movement:** The attackers moved from the compromised vendor portal to the main network and then to the POS systems, where they installed malware to scrape credit card data from memory.
- **Data Exfiltration:** 40 million credit and debit card records were stolen.

Case Study: Target Data Breach (2013) II

- **Detection Failure:** FireEye, a security vendor, detected the malware and alerted Target's security operations center (SOC). The alerts were investigated and subsequently ignored, a failure of internal process.
- **Cost:** The breach cost Target over \$292 million in settlements and led to the resignation of the CEO.
- **Lessons:** The breach is a textbook case of the importance of:
 - **Third-party Risk Management:** Vendor access must be strictly controlled and monitored.
 - **Network Segmentation:** Isolating payment systems from other networks.
 - **SOC Process:** Alerts must be escalated and acted upon, not ignored.

Case Study: Mirai Botnet (2016) I

- **Target:** Insecure IoT devices: IP cameras, home routers, and DVRs.
- **Propagation:** Mirai scanned the internet for devices with open Telnet (port 23) or SSH (port 22) ports. It then attempted to log in using a list of 60 default credentials (e.g., `root:root`, `admin:admin`). Successful infections turned devices into bots.
- **Botnet Size:** At its peak, Mirai was estimated to have over 600,000 infected devices.
- **Attacks:**
 - **KrebsOnSecurity:** Launched a 620 Gbps DDoS attack against security journalist Brian Krebs' website.
 - **Dyn DNS:** A massive DDoS attack against DNS provider Dyn, taking down major websites like Twitter, Netflix, Reddit, and GitHub for a large part of the US East Coast.

Case Study: Mirai Botnet (2016) II

- **Impact:** Demonstrated the power of IoT botnets. The Mirai source code was released on public forums, leading to a proliferation of copycat botnets.
- **Lessons:**
 - **IoT Security Negligence:** Manufacturers ship devices with default credentials and no auto-update mechanisms, creating a vast vulnerable attack surface.
 - **Importance of Changing Defaults:** A simple, fundamental security hygiene practice (changing the default password) would have prevented most of the infections.
 - **DDoS Mitigation:** Organizations must have DDoS protection plans (e.g., scrubbing centers) to handle volumetric attacks.

- **Vulnerability Scanning:** Automated scanning using tools like Nessus, OpenVAS, or Qualys. The scanner probes the network for known vulnerabilities, such as missing patches, weak encryption, and default credentials. It provides a high-level snapshot of security posture.
- **Penetration Testing:** A human-led, simulated attack. A penetration tester attempts to exploit vulnerabilities to gain access, escalate privileges, and move laterally. It goes beyond scanning to demonstrate real-world impact.
- **Red Team Exercises:** A full-scope adversarial simulation. A "red team" acts as an adversary, using any means necessary (network, physical, social engineering) to achieve a specific objective, while a "blue team" defends. It tests detection and response capabilities.

Network Security Testing II

- **Fuzz Testing (Fuzzing):** Sending malformed, unexpected, or random data (fuzz) to network services to trigger crashes, memory leaks, or unhandled exceptions that could be exploitable.
- **Configuration Review:** A manual review of device configurations (routers, firewalls, switches) against industry best practices (e.g., CIS Benchmarks, NIST guidelines). Common issues include default credentials, weak SNMP strings, and overly permissive ACLs.
- **War Dialing:** An old but still relevant test. It scans telephone numbers for modems. An unsecured modem is a backdoor into a network.
- **Wireless Assessment:** A focused test of the wireless environment. It involves detecting rogue APs, cracking WPA2 handshakes, and testing the security of 802.1X deployments.

Future of Network Security I

- **Zero Trust Adoption:** Zero Trust will become the dominant security model. The focus will shift from network perimeter to identity and device-based access, driven by cloud migration and remote work.
- **AI/ML in Security:** Artificial Intelligence and Machine Learning will automate more of the detection and response lifecycle. AI-powered SIEMs and SOAR (Security Orchestration, Automation, and Response) platforms will reduce manual analyst work. However, attackers will also use AI to create more sophisticated, polymorphic malware.
- **SASE (Secure Access Service Edge) Convergence:** The trend of converging networking (SD-WAN) and security (SWG, CASB, ZTNA) into a single, cloud-delivered service will accelerate, replacing traditional hardware-based network security stacks.

- **Quantum-Safe Networks:** Over the next decade, organizations will begin the long process of migrating to post-quantum cryptography (PQC), starting with the most sensitive data and communications.
- **Automated Security (Self-Healing Networks):** Networks will become more autonomous, capable of detecting threats and automatically reconfiguring (e.g., isolating a compromised host, rerouting traffic) without human intervention.
- **Increased Encryption:** As TLS 1.3 and DNS over HTTPS (DoH) become standard, less and less network traffic will be visible in plaintext. This will force security teams to rely entirely on encrypted traffic analysis (ETA) and identity-centric controls.

- **Regulatory Pressure:** Governments (including India with the DPDPA and CERT-In directives) will continue to enact stricter regulations, mandating data localization, breach notification, and specific security controls.

Thank you!